

Cyber Security Case Study and Risk Prevention Report

Date: June 25, 2026

To: Management,

From: Muhammad Talha, Security Analyst

Subject: Analysis of Customer Data Leak and Recommendations for Enhanced Security Posture

1. Analysis of Mistakes

The recent data leak experienced by our company is a direct result of a confluence of fundamental security failures. These mistakes are not unique but represent common pitfalls that many small businesses fall into. A thorough analysis reveals the following critical mistakes made by both the company and its employees:

- **Absence of a Strong Password Policy:** The company's policy of allowing "simple passwords" is a critical error. This creates a vulnerability to brute-force attacks, where stolen credentials from other data breaches are used to access our systems. This single point of failure is the most direct enabler for unauthorized access.
- **Lack of Network Security Awareness:** Employees using public Wi-Fi networks to access sensitive company systems is a severe security oversight. Public Wi-Fi, like that found in cafes and airports, is notoriously insecure. They are often unencrypted, allowing attackers on the same network to intercept data transmitted between the employee's device and the company's servers. This is a classic "man-in-the-middle" (MitM) attack scenario.
- **Unrestricted Device Access (BYOD without Policy):** The scenario implies employees use "different devices" to access the system. Without a formal "Bring Your Own Device" (BYOD) policy, the company has no control over the security posture of these devices.
- **Lack of Monitoring and Alerting:** The fact that the company only noticed the attack *after* the data was leaked indicates a lack of real-time monitoring and alerting systems. Effective security requires not just prevention but also detection. Intrusion detection and prevention systems (IDPS) could have flagged the "unusual login activity" in real-time, allowing for a faster response and potentially preventing the data exfiltration.
- **Insufficient Access Control:** The case study does not mention any form of access control beyond a simple password. Employees likely have more access to data than necessary. A

lack of role-based access control (RBAC) , an attacker gains access to the entire customer database, rather than just a limited subset of data.

- **Inadequate Data Security Measures:** The data itself was stored in a manner that allowed it to be "leaked." This points to a failure in applying security at the data layer. The data was likely unencrypted while at rest on the server, meaning that once the attacker bypassed the login, the data was in a readable format and easily copied.

The **cyber risks** involved in this situation are multifold and severe. They include:

- **Financial Risk:** Costs associated with forensic investigation, legal counsel, notification to affected customers, potential regulatory fines (e.g., from GDPR or CCPA), and loss of business due to reputational damage.
- **Reputational Risk:** A data breach erodes customer trust, which can be incredibly difficult and costly to rebuild.
- **Operational Risk:** The company's operations could be disrupted during the investigation and remediation process.
- **Legal Risk:** The company faces potential lawsuits from affected customers and scrutiny from data protection authorities.

2. Identify Threats

Based on the scenario, we can identify at least five specific cyber threats that materialized or were highly likely to have contributed to the data leak:

1. **Credential Brute-Force Attack:** An attacker uses automated tools to systematically try a vast number of common or weak passwords against employee login accounts until they guess correctly.
2. **Man-in-the-Middle (MitM) Attack:** An attacker intercepts communications between an employee and the company website over an unsecured public Wi-Fi network, capturing the login credentials in plaintext.
3. **Credential Stuffing:** An attacker uses a database of usernames and passwords previously leaked from other websites to try and log in to our company's systems, relying on the common practice of password reuse by employees.
4. **Malware Infection:** An employee's personal device connected to public Wi-Fi could become infected with malware, such as a keylogger. This malware could then capture keystrokes to steal passwords or other sensitive information and send it to an attacker's command-and-control server.
5. **Insider Threat :** An employee could be socially engineered (e.g., via a phishing email) to reveal their credentials or other sensitive information, which is then used by the attacker to gain access. This threat is amplified by a lack of security awareness training.

3. Proposed Solutions

To address the identified mistakes and mitigate future risks, we propose the following practical security solutions:

1. **Enforce a Robust Password Policy:** Implement a company-wide policy mandating strong, complex passwords (e.g., minimum 12 characters, requiring uppercase, lowercase, numbers, and symbols). This eliminates the risks of weak passwords and password reuse.
2. **Mandate the Use of a Virtual Private Network (VPN):** All employees must be required to use a company-approved VPN whenever they are outside the secure office network. A VPN creates an encrypted tunnel for all internet traffic,
3. **Deploy Multi-Factor Authentication (MFA):** Implement MFA for all user accounts, especially those with access to sensitive data. Even if an attacker acquires a valid password, they will be unable to log in without the second verification factor.
4. **Implement Endpoint Protection and Device Management:** Adopt a Mobile Device Management (MDM) or Endpoint Detection and Response (EDR) solution. This allows the company to enforce security policies on all devices that access company data. Devices that do not meet these security baselines can be blocked from accessing the system.
5. **Adopt Role-Based Access Control (RBAC):** Implement a principle of "least privilege." This means granting employees only the access rights necessary to perform their specific job functions. For example, a marketing employee should not have access to sensitive financial data or the entire customer database. This limits the potential damage from compromised credentials.
6. **Encrypt Data at Rest and in Transit:** Ensure that all sensitive data (the customer database) is encrypted when stored on servers (data at rest). This means that even if an attacker bypasses other controls and gains access to the server's file system, the data will be unreadable without the encryption key. Data in transit is protected by the VPN as mentioned above.

4. Security Improvement Plan

To immediately improve our security posture, we must take decisive action. The following is a step-by-step plan to be executed on a priority basis.

- **Step 1: Containment and Investigation (Days 1-2):**
 - **Action:** Immediately force a password reset for all user accounts.
 - **Action:** Engage an external cybersecurity forensics team to conduct a thorough investigation to determine the full scope of the breach, how the attacker entered, and what data was accessed or exfiltrated.
 - **Action:** Back up all critical and potentially compromised data and systems in a secure, offline manner.
- **Step 2: Secure Access Points (Days 3-5):**
 - **Action:** Mandate the use of a company-provided VPN for all remote employees. This is a critical non-negotiable requirement for accessing company resources from outside the office.
 - **Action:** Enroll all employees in an approved password manager and enforce its use for all company-related accounts.
 - **Action:** Begin the rollout of MFA. Activate it for all administrative and high-privilege accounts immediately, and plan for full deployment across all accounts within the

week.

- **Step 3: Patch and Harden Systems (Days 5-7):**

- **Action:** Conduct a full audit of all servers, workstations, and network devices. Apply all critical security patches and software updates to eliminate known vulnerabilities.
- **Action:** Review and modify firewall rules to ensure only necessary ports are open to the internet.

- **Step 4: Policy and Training Overhaul (Days 7-14):**

- **Action:** Draft and implement a comprehensive BYOD policy that clearly defines acceptable use and security requirements for personal devices.
- **Action:** Draft and implement a clear and concise password policy, as well as an Acceptable Use Policy.
- **Action:** Conduct a mandatory security awareness training session for *all* employees. This training must cover:
 - The critical importance of strong passwords and password managers.
 - How to identify and report phishing attempts.
 - The dangers of using unsecured public Wi-Fi.
 - The company's new security policies and procedures.

- **Step 5: Implement Monitoring and Data Protection (Day 15 and ongoing):**

- **Action:** Deploy a Security Information and Event Management (SIEM) system or a similar logging and monitoring solution to provide real-time analysis of security alerts and detect suspicious activities.
- **Action:** Implement a solution for encrypting data at rest, starting with the customer database.
- **Action:** Review and implement a Principle of Least Privilege model for all user access, ensuring users only have access to the data they need.

- **Step 6: Ongoing Vigilance (Ongoing):**

- **Action:** Establish a schedule for regular security audits (e.g., quarterly).
- **Action:** Schedule recurring security awareness training and simulated phishing exercises.
- **Action:** Create a documented incident response plan (IRP) so the company has a clear, pre-defined playbook to follow in the event of a future security incident, significantly reducing response time and potential damage